in the original query but can also query other tables in the database.

3. b - The attacker can get the program to allocate large byte arrays based on user input. For a Java `int` value, the maximum would be a 2GB array, which would probably allow the attacker to exhaust all available memory with a few requests. While passing invalid values is an annoyance, recall from the start of section 2.5 that Java is a memory-safe language and so these will result in exceptions rather than insecure behavior.
4. d - `X-Content-Type-Options: nosniff` instructs browsers to respect the Content-Type header on the response.
5. b and e. You should never include un-sanitized input values in error messages, as this may allow an attacker to inject XSS scripts. You should also never copy the Accept header from the request into the Content-Type header of a response, but instead construct it from scratch based on the actual content type that was produced.

[1] See https://adamcaudill.com/2017/10/04/exploiting-jackson-rce-cve-2017-7525/ for a description of the vulnerability. The vulnerability relies on a feature of Jackson that is disabled by default.

[2] You may hear the older terms *whitelist* and *blacklist* used for these concepts, but these words can have negative connotations and should be avoided. See https://www.ncsc.gov.uk/blog-post/terminology-its-not-black-and-white for a discussion.

[3] Java 11 appears to be less susceptible to these attacks than earlier versions.

[4] See https://scotthelme.co.uk/edge-to-remove-xss-auditor/ for a discussion of the implications of Microsoft's announcement. Google have now also announced plans to remove their XSS Auditor and Firefox never implemented the protections in the first place, so this protection will soon be gone from all major browsers.